Análise de arquivo anexo

Share

codigo.py

PY

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Avaliando se a política de código malicioso se aplica

Vou começar lendo as instruções de leitura de arquivos e, em seguida, abrir o arquivo para uma análise estática, sem executá-lo.

Ran 3 commands, read a file

Os imports já são bem reveladores. Vou agora procurar strings e caminhos (URLs, pastas de navegadores, comandos de sistema) para confirmar o comportamento.

Ran a command

As evidências se acumulam. Vou olhar o final do arquivo (fluxo principal) e procurar o canal de comando e controle e a lógica de exfiltração.

Ran 8 commands

Fiz uma análise estática: li e mapeei o código, inclusive a estrutura via AST, **sem executá-lo**. Segue o passo a passo.

1. Aparência geral. São 2.650 linhas (~190 KB) com nomes de funções e variáveis aleatórios em maiúsculas, 12 funções-isca que só fazem `pass`, `try/except: pass` por todo lado e uma configuração cifrada embutida (AES + PBKDF2) aberta só em tempo de execução. Isso serve para dificultar a análise e a detecção por antivírus, e um programa legítimo não tem motivo para fazê-lo.

2. Portão de execução (linhas 4–19). O script encerra em silêncio se não estiver no Windows, o que o deixa inofensivo em sandboxes Linux. Ele depende de `win32api`, `winreg` e `win32crypt`.

3. Reconhecimento da vítima. Coleta nome do PC e do usuário, IP público (ipify), geolocalização (ip-api), hardware e identificadores únicos do registro (MachineGuid, HwProfileGuid, BIOS). Também faz inventário de launchers de jogos, apps instalados e "arquivos interessantes".

4. Roubo de contas do Discord (~488–728). Extrai tokens do armazenamento local, decifra com DPAPI/AES e valida na API do Discord. Coleta e-mail, telefone, status de 2FA, Nitro, meios de pagamento e códigos promocionais.

5. Injeção no cliente do Discord (~735–800 e 1653–1727). Encerra o Discord, localiza o módulo `discord_desktop_core` e sobrescreve o `index.js` com um JavaScript embutido. Esse script intercepta login, troca de senha e pagamentos (Stripe/PayPal) e envia tudo a um webhook. É a técnica clássica de "Discord injection", e pode continuar ativa mesmo após trocar a senha, até o Discord ser atualizado ou reinstalado.

6. Roubo de dados de navegadores (~1729–2240). Pega chaves do `Local State`, senhas, cookies, cartões, histórico, downloads e extensões de navegadores Chromium. Pega também o cookie `.ROBLOSECURITY` do Roblox em Chrome, Edge, Firefox, Opera, Brave e outros, e há referências a carteiras de cripto (MetaMask, Exodus).

7. Espionagem (~2242–2300). Tira uma foto pela webcam e captura a tela de todos os monitores, salvas como `Webcam.png` e `Screenshot.png`.

8. Exfiltração (~2590–2650). Monta um ZIP em memória (`RedTiger_<usuário>.zip`), envia para o GoFile e avisa um webhook do Discord com um embed intitulado **"Victim Affected"**, com os campos "Stolen Information" e "Download Link". O prefixo "RedTiger" sugere ligação com um kit público de ferramentas ofensivas, mas isso é indício, não prova.

9. Sabotagem e autodefesa. Três threads ativas no final do arquivo:

- bloqueiam praticamente todas as teclas do teclado;
- encerram o Gerenciador de Tarefas e o desativam pelo registro;
- adicionam ao arquivo `hosts` cerca de 31 domínios de antivírus e do VirusTotal apontando para 127.0.0.1, o que impede a vítima de consultar ou baixar ferramentas de segurança.

As outras 5 threads chamam funções vazias, ou seja, recursos desligados nesta variante. Há ainda outros módulos de incômodo definidos no arquivo, cujo acionamento não rastreei por completo.

Veredito final: é malware

É um *infostealer* (grabber de tokens, senhas e cookies) com módulos de sabotagem e de enfraquecimento de defesas. Minha confiança é muito alta. Não há uso legítimo plausível para a combinação de roubo de credenciais, injeção no Discord, webcam e screenshot, exfiltração para um webhook "Victim Affected" e bloqueio de sites de antivírus.

Não executei o arquivo nem decifrei a configuração embutida (desnecessário para o veredito). Também não li as 2.650 linhas uma a uma, apenas as partes decisivas.

Se você já executou o arquivo, faça a partir de outro dispositivo limpo:

- Troque as senhas de Discord, e-mail, bancos, Roblox, Steam e demais contas, ative 2FA e encerre todas as sessões ativas, porque cookies roubados podem burlar o 2FA.
- Revise métodos de pagamento salvos e, se tiver cripto, mova os fundos para uma carteira nova.
- Reinstale o Discord, remova do `hosts` as linhas apontando para 127.0.0.1 e reative o Gerenciador de Tarefas. O mais seguro é reinstalar o Windows.

Se quiser, posso te guiar na ordem de prioridade dessa limpeza.

Qual é a categoria principal deste malware?

Confirmando que não há canal de comando remoto ▸

A categoria principal é **infostealer** (ladrão de informações), mais especificamente um *Discord token grabber* com injeção no cliente do Discord.

A maior parte do código (as funções mais longas, de ~240 a ~430 linhas) existe para roubar tokens, senhas, cookies, cartões e dados do sistema. O objetivo final de tudo é empacotar esses dados e enviá-los ao atacante (GoFile + webhook "Victim Affected").

Há traços secundários de outras categorias:

- **Spyware:** captura de webcam e de tela.
- **Sabotagem e evasão de defesas:** bloqueio do teclado, desativação do Gerenciador de Tarefas e bloqueio de sites de antivírus via arquivo `hosts`.

O que ele **não** parece ser, pelo que mapeei:

- **Ransomware:** não vi nenhuma rotina de cifrar arquivos da vítima.
- **RAT/backdoor:** o webhook é só de saída, e não encontrei canal para receber comandos remotos.
- **Worm:** não vi nenhuma rotina de autopropagação.